

الدبلوم العالي - محاضرة أكاديمية

إطار COBIT 2019 وحوكمة تكنولوجيا المعلومات

COBIT (Control Objectives for Information and Related Technology) by
ISACA (Information Systems Audit and Control Association)

إعداد :

أ.د. ضياء جاسم كاظم

محاور الدراسة الرئيسية



تكامل الأمن السيبراني

ربط الأهداف الأمنية بإطار COBIT والمعايير الدولية ISO

و NIST



هيكلية COBIT 2019

المبادئ التسعة والمكونات السبعة والنموذج المرجعي لـ 40

هدفاً.



مفاهيم الحوكمة

التمييز بين الحوكمة والإدارة وتحديد الأدوار والمسؤوليات.

ما هي حوكمة تكنولوجيا المعلومات؟

مجموعة المبادئ والتنظيمات التي تضمن دعم تقنية المعلومات لأهداف المؤسسة الاستراتيجية وتحقيق القيمة المضافة.

الغاية الجوهرية للحوكمة

تحقيق التوازن الأمثل بين خلق القيمة وتحسين المستويات الأمنية وتقليل المخاطر.

الأركان الثلاثة للحوكمة

- ✓ تحقيق الفوائد: تعظيم العائد من الاستثمار الرقمي.
- ✓ تحسين المخاطر: حماية الأصول والمعلومات الحساسة.
- ✓ أمثلة الموارد: الاستخدام الكفء للبنية التحتية.

التميز الجوهري: الحوكمة مقابل الإدارة

مسؤولية الإدارة التنفيذية

الإدارة (Management)

تختص بالتخطيط والبناء التشغيلي والتنفيذ اليومي للأنشطة.

الأنشطة: التخطيط - (Plan) البناء - (Build) التشغيل (Run)

مسؤولية مجلس الإدارة

الحوكمة (Governance)

تختص بالتوجيه والتقييم والمراقبة لضمان تحقيق الأهداف العليا.

الأنشطة: التقييم - (Evaluate) التوجيه - (Direct) المراقبة (Monitor)

تعريف إطار COBIT 2019

إطار عمل عالمي طورته منظمة ISACA يوفر منهجية شاملة لحوكمة وإدارة المعلومات والتكنولوجيا في المؤسسات.



معياري قطاعي عالمي

جسر يربط الفجوة بين الإدارة العليا وفرق الأمن السيبراني
وتقنية المعلومات.

تطور الإطار: صدر عام 2019 ليتناسب مع التقنيات الحديثة والتحول الرقمي.

الميز الأساسية: المرونة العالية والملاءمة مع متطلبات كل مؤسسة.

ISACA اختصاراً لـ Information Systems Audit and Control Association هي جمعية مهنية عالمية غير ربحية تُعنى بحوكمة

تكنولوجيا المعلومات، التدقيق، إدارة المخاطر، والأمن السيبراني. تأسست عام 1969 وتعد المرجع الأول دولياً لتطوير ممارسات وأطر العمل في هذه

المجالات.

المبادئ الستة لنظام الحوكمة

1. تلبية احتياجات الأطراف

توليد القيمة وأهداف الأعمال.

2. النهج الشامل

تغطية المؤسسة كمنظومة متكاملة.

3. نظام ديناميكي

التكيف المستمر مع المتغيرات.

4. فصل الحوكمة عن الإدارة

تمكين واضح للأدوار والمسؤوليات.

5. التخصيص حسب الاحتياج

تعديل النظام وفق سياق المؤسسة.

6. حوكمة شاملة للطرفين

تغطية التقنية والبيانات والمخاطر.

مبادئ إطار الحوكمة الثلاثة

1. مبني على المكونات

يعتمد على عناصر تفاعلية توفر النظام الحاكم بكل فاعلية.

2. مفتوح وحيوي

يتيح إضافة مستويات وأساليب جديدة دون الإخلال بالمرجعية.

متوافق مع المعايير

يتنسق مع الأطر والأنظمة المعترف بها ك ISO & NIST

المكونات السبعة لنظام الحوكمة (Governance Components)



المعلومات والبيانات



المبادئ والسياسات



الهيكل التنظيمية



العمليات (Processes)



الأفراد والمهارات



الخدمات والتطبيقات



الثقافة والسلوكيات

مجالات COBIT 2019 الخمسة (40 أهداف حوكمة وإدارة)

مجال الحوكمة EDM :

(Evaluate, Direct, Monitor)

5 أهداف

التوافق والتخطيط والتنظيم

14 هدفاً

البناء والتملك والتطبيق

11 هدفاً

التقديم والخدمة الدعم (العمليات والأمن)

6 أهداف

الرصد والتقييم والقياس

4 أهداف

أهداف الحوكمة المباشرة للأمن السيبراني

DSS05 إطار

إدارة خدمات الأمن التشغيلية

حماية الأنظمة التشغيلية من الاختراقات وإدارة الصلاحيات والتعامل المباشر مع الحوادث والتهديدات.

APO13 إطار

إدارة الأمن الرقمي (Managed Security)

صياغة وتحديث نظام إدارة أمن المعلومات (ISMS) وتحديد مستويات الحماية ومتابعة تنفيذ السياسات.

عوامل التصميم (Design Factors)

ملف التهديدات السيبرانية (Threat Landscape) 

المتطلبات التنظيمية والامتثال القانوني 

دور وتطور تقنية المعلومات بالمؤسسة 

استراتيجية واستجابة المؤسسة للمخاطر 

تسمح عوامل التصميم بتكييف إطار COBIT 2019 ليناسب البيئة الأمنية والمخاطر الخاصة بكل مؤسسة.

النتيجة التنفيذية

بناء نظام حوكمة أمني مخصص خالٍ من التعقيد الزائد.

مستويات القدرة والنضج (Capability Levels 0-5)

5

مُحسّن

تطوير مستمر وابتكار

4

قابل للقياس

قياس كمي ومؤشرات أداء

3

مُحدد

توثيق ومعايير موحدة

2

مُدّار

تخطيط وقياس ومراجعة

1

مُنَفَّذ

تحقيق الهدف بشكل أولي

0

غير مكتمل

غياب الأنشطة والضوابط

التكامل بين COBIT 2019 والأطر العالمية الأخرى



ITIL 4

يدعم إدارة الخدمات التشغيلية التي تعتمد عليها الحوكمة.



NIST CSF

يركز على إدارة المخاطر الاستجابة المباشرة للحوادث والتعافي.



ISO/IEC 27001

يوفر الضوابط التفصيلية لأمن المعلومات التي تحقق أهداف
COBIT.

خطوات حوكمة حادث سيراني باستخدام COBIT 2019

1 التوجيه والتقييم (EDM03)

تحديد مستوى المخاطر المقبول وتوجيه سياسة الاستجابة للحوادث.

2 التخطيط والتنظيم (APO12)

تقييم أثر الحادث على الأصول والمعلومات وتحديد خطة الطوارئ.

3 التشغيل والاحتواء (DSS05)

تنفيذ إجراءات الاحتواء والأمن التقني ومعالجة الثغرة بشكل مباشر.